

عنوان پروژه: تحلیل کمی تاب‌آوری سایبری: تحلیل گراف حمله احتمالی (PAG) در معماری‌های Zero-Trust

هدف پروژه: این پروژه فراتر از تحلیل‌های کلاسیک "قابلیت اطمینان" (آیا سیستم کار می‌کند؟) حرکت کرده و به تحلیل امنیت احتمالی (آیا سیستم امن است؟) می‌پردازد. هدف این است که با استفاده از نظریه گراف و کتابخانه NetworkX، یک معماری میکروسرویس (مانند کلاستر Kubernetes) را مدل‌سازی کنید و با استفاده از "گراف‌های حمله احتمالی (Probabilistic Attack Graphs)، بسنجید که یک مهاجم با چه احتمالی و از چه مسیری می‌تواند به دارایی‌های حیاتی (مثل دیتابیس) نفوذ کند. در نهایت، تأثیر اعمال سیاست‌های Zero-Trust (حذف دسترسی‌های غیرضروری) را بر کاهش ریسک سیستم ارزیابی نمایید.

فرایند پیاده‌سازی (NetworkX, Python):

۱. مدل‌سازی سیستم ("دوقلوی دیجیتال" - Digital Twin): یک گراف جهت‌دار (nx.DiGraph) ایجاد کنید که نمایانگر یک کلاستر میکروسرویس باشد:

- گره‌ها (Nodes): نمایانگر دارایی‌ها هستند (مانند Web_Gateway, Auth_Service, User_DB, Lambda_Function).

○ ویژگی‌ها: برای هر گره ویژگی‌هایی تعریف کنید: نوع سرویس، لایه (External/Internal/Core) و امتیاز آسیب‌پذیری (بر اساس استاندارد CVSS، عددی بین ۰ تا ۱).

- یال‌ها (Edges): نمایانگر دسترسی شبکه یا مجوزهای عبور هستند.

○ وزن یال (ASR - Attack Success Rate): احتمال اینکه یک مهاجم بتواند از گره A به گره B نفوذ کند (مثلاً ۰.۸ برای ارتباطات ناامن و ۰.۱ برای ارتباطات رمزنگاری شده/ایمن).

۲. پیاده‌سازی سناریوهای تحلیل (Simulation Logic): باید الگوریتم‌های زیر را برای تحلیل گراف پیاده‌سازی کنید:

- الف) الگوریتم "محتمل‌ترین مسیر حمله" (Most Likely Attack Path - MLAP):

○ به جای پیدا کردن کوتاه‌ترین مسیر (Shortest Path)، مسیری را بیابید که حاصل ضرب احتمالات (وزن یال‌ها) در آن بیشینه باشد.

○ راهنمایی: می‌توانید از نسخه تغییر یافته دایکسترا (Modified Dijkstra) استفاده کنید (یا تبدیل وزن‌ها به $-\log(p)$).

$$P_{path} = P(Edge1) \times P(Edge2) \times \dots$$

- (ب) شبیه‌سازی مونت کارلو (Monte Carlo Attack Simulation):
 - یک "مهاجم" مجازی را در گره ورودی (مثلاً Web_Gateway) قرار دهید.
 - در هر گام، مهاجم سعی می‌کند بر اساس وزن یال‌ها (احتمال موفقیت) به گره‌های همسایه حرکت کند (یک یا چند گره).
 - این فرایند را $N=1000$ بار تکرار کنید تا ببینید مهاجم در چند درصد موارد موفق به رسیدن به دیتابیس (Target) می‌شود.

۳. مقایسه معماری‌ها (Zero-Trust Evaluation): شبیه‌سازی‌های مرحله ۲ را روی دو توپولوژی متفاوت اجرا و مقایسه کنید:

- شبکه مسطح (Default Flat Network): حالتی که اکثر میکروسرویس‌ها به هم دسترسی دارند (اتصال بالا، امنیت پایین).
- شبکه Zero-Trust: حالتی که با استفاده از الگوریتم‌های تشخیص جامعه (nx.community) یا برش دستی، یال‌های غیرضروری (که ارزش عملیاتی کم اما ریسک بالا دارند) حذف شده‌اند.

۴. معیارهای ارزیابی:

- شعاع انفجار شبکه (Network Blast Radius): میانگین تعداد گره‌هایی که یک مهاجم می‌تواند از یک نقطه شروع خاص تسخیر کند.
- احتمال نفوذ کلی (Overall Compromise Probability): درصدی از اجراهای مونت کارلو که در آن مهاجم به "هدف نهایی" رسیده است.
- معیار RASR (Robustness-Attack Success Rate): معیاری برای سنجش اینکه شبکه چقدر در برابر حملات احتمالی مقاوم است (برگرفته از مقاله مرجع اول).

۵. نمودارها و خروجی‌ها:

۱. بصری‌سازی گراف حمله (Attack Graph Visualization):

- استفاده از nx.draw_kamada_kawai یا موارد مشابه.
- رنگ‌بندی: گره‌ها را بر اساس "احتمال تسخیر شدن" رنگ‌آمیزی کنید (Heatmap: قرمز = نفوذ آسان، سبز = امن).
- هایلایت مسیر بحرانی: کل گراف را با رنگ خاکستری نمایش دهید، اما "محتمل‌ترین مسیر حمله" (MLAP) را با خط ضخیم قرمز مشخص کنید.

۲. نمودار سطح ریسک (Risk Surface Plot):

- محور X: تراکم اتصالات (Connectivity Density).
- محور Y: میانگین امتیاز آسیب‌پذیری گره‌ها (Vulnerability Score).

- رنگ/محور Z: امتیاز ریسک سیستم (یا احتمال نفوذ نهایی).
- هدف: نشان دادن اینکه چگونه ترکیب آسیب‌پذیری و اتصالات زیاد، ریسک را به صورت نمایی بالا می‌برد.

۳. تحلیل آزاد:

- با توجه به دانش کسب شده، ۲ فرضیه مطرح کرده (مثلاً تأثیر قرار دادن فایروال در گره‌های خاص) و آزمایشی برای اثبات یا رد آن‌ها طراحی کرده و نتایج و نمودارهای خود را تحلیل کنید.

۶. بخش امتیازی (اختیاری): تحلیل‌های پیشرفته:

- وصله کردن هوشمند (Smart Patching Strategy): فرض کنید بودجه محدودی دارید و تنها می‌توانید K یال یا گره را ایمن‌سازی کنید (وزن آن‌ها را کاهش دهید). الگوریتمی بنویسید (مثلاً حریصانه) که بهترین کاندیدها برای ایمن‌سازی را پیدا کند تا "محتمل‌ترین مسیر حمله" بیشترین افت احتمال را داشته باشد (در انتخاب بهترین استراتژی در این بخش می‌توانید به روش دلخواه خود عمل کنید)
- تحلیل پویایی زمان (Dynamic Reliability): فرض کنید با گذشت زمان، آسیب‌پذیری‌های جدید کشف می‌شوند (وزن‌ها زیاد می‌شوند) و پیچ‌های امنیتی اعمال می‌شوند (وزن‌ها کم می‌شوند). یک شبیه‌سازی در طول زمان (t گام) انجام دهید و نوسان امنیت شبکه را رسم کنید.

۷. موارد تحویلی:

دانشجویان باید موارد زیر را در قالب یک فایل Zip ارسال کنند:

- سورس کد (Python/Jupyter): کدها باید خوانا، دارای توضیحات و قابل اجرا باشند. پیاده‌سازی کلاس AttackGraph توصیه می‌شود.
- گزارش نهایی (PDF): شامل مقدمه، تشریح مدل ریاضی استفاده شده برای محاسبه احتمالات، نمودارها (Heatmap) و تحلیل دقیق مقایسه بین معماری Flat و Zero-Trust. پاسخ به این سوال کلیدی: "آیا Zero-Trust همیشه امنیت را بالا می‌برد یا ممکن است دسترس‌پذیری را مختل کند؟" و...

References:

- Analyzing the Robustness of Complex Networks with Attack Success Rate
[Analyzing the Robustness of Complex Networks with Attack Success Rate](#)
- Microservice Vulnerability Analysis: A Literature Review With Empirical Insights
[Microservice Vulnerability Analysis: A Literature Review With Empirical Insights | IEEE Journals & Magazine | IEEE Xplore](#)
- Most Vulnerable Attack Trace in a Probabilistic Attack Graph
[Most Vulnerable Attack Trace in a Probabilistic Attack Graph | IEEE Conference Publication | IEEE Xplore](#)